

Hammered Lab[端點取證]

這項挑戰將帶您進入虛擬系統並分析令人困惑的日誌資料。在本挑戰中，您將扮演 SOC 分析師，利用來自可能已受感染伺服器的日誌，找出該 Web 伺服器蜜罐發生了什麼事。

感謝th3c0rt3x審查這項挑戰。

Tools:

Linux Command Line Tools

grep

Text Editor

問題 1

攻擊者使用哪種服務來存取系統？

指令:cat auth.log|grep "fail"

```
Apr 24 13:07:30 app-1 sshd[25492]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:32 app-1 sshd[25494]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:35 app-1 sshd[25496]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:37 app-1 sshd[25498]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:40 app-1 sshd[25500]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:41 app-1 sshd[25502]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:43 app-1 sshd[25504]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:46 app-1 sshd[25506]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:48 app-1 sshd[25508]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:50 app-1 sshd[25510]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:52 app-1 sshd[25512]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:54 app-1 sshd[25514]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:56 app-1 sshd[25516]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:07:59 app-1 sshd[25518]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:01 app-1 sshd[25520]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:03 app-1 sshd[25522]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:06 app-1 sshd[25524]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:08 app-1 sshd[25526]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:11 app-1 sshd[25528]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:13 app-1 sshd[25530]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:16 app-1 sshd[25532]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:17 app-1 sshd[25534]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:18 app-1 sshd[25536]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:21 app-1 sshd[25538]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:24 app-1 sshd[25540]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:25 app-1 sshd[25542]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:28 app-1 sshd[25544]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:29 app-1 sshd[25546]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:32 app-1 sshd[25548]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:35 app-1 sshd[25550]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:36 app-1 sshd[25552]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:38 app-1 sshd[25554]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:40 app-1 sshd[25557]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:42 app-1 sshd[25559]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:44 app-1 sshd[25561]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:47 app-1 sshd[25563]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:48 app-1 sshd[25565]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:50 app-1 sshd[25567]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:52 app-1 sshd[25569]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:54 app-1 sshd[25571]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:56 app-1 sshd[25573]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:08:59 app-1 sshd[25575]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 13:09:01 app-1 sshd[25577]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
```

ssh

第二季

目標系統的作業系統版本是什麼？

指令:cat dmesg

```
(root@kali)-[/home/kali/Desktop/temp_extract_dir/Hammered]
# cat dmesg
[ 0.000000] Initializing cgroup subsys cpuset
[ 0.000000] Initializing cgroup subsys cpu
[ 0.000000] Linux version 2.6.24-26-server (buildd@crested) (gcc version 4.2.4 (Ubuntu 4.2.4-1ubuntu3)) #1 SMP Tue Dec 1 18:26:43 UTC 2009 (Ubuntu 2.6.2
4-26.64-server)
[ 0.000000] Command line: root=UUID=36017f23-24b7-482d-955f-406e5acd82a3 ro quiet splash
4.2.4-1ubuntu3
```

第三季

被盜用的帳戶名稱是什麼？

同Q1

root

第四季

有多少攻擊者 (以唯一 IP 位址為代表) 在初次嘗試失敗後能夠成功存取系統？

指令:cat auth.log| grep "Accepted password" | awk '{print \$9,\$11}' | sort | uniq -c | sort -n

```
(root@kali)-[/home/kali/Desktop/temp_extract_dir/Hammered]
# cat auth.log| grep "Accepted password" | awk '{print $9,$11}' | sort | uniq -c | sort -n
1 fido 94.52.185.9
1 root 10.0.1.2
1 root 151.81.204.141
1 root 151.81.205.100
1 root 151.82.3.201
1 root 188.131.22.69
1 root 190.167.70.87
1 root 190.167.74.184
1 root 193.1.186.197
1 root 201.229.176.217
1 root 222.169.224.197
1 root 222.66.204.246
1 root 61.168.227.12
1 root 94.52.185.9
1 user1 166.129.196.88
1 user1 208.80.69.70
1 user1 65.195.182.120
1 user1 67.164.72.181
1 user3 208.80.69.74
1 user3 65.195.182.120
2 dhg 190.167.74.184
2 root 121.11.66.70
2 root 122.226.202.12
2 user3 208.80.69.69
3 root 190.166.87.164
3 user3 192.168.126.1
4 root 188.131.23.37
4 root 219.150.161.20
4 user3 10.0.1.4
5 user2 71.132.129.212
6 user1 208.80.69.74
6 user1 65.88.2.5
13 user3 10.0.1.2
20 dhg 190.166.87.164
22 user1 76.191.195.140
```

縮小範圍，只看使用者

指令:cat auth.log| grep "Accepted password" | awk '{print \$9}' | sort | uniq -c | sort -n

```
(root@kali)-[/home/kali/Desktop/temp_extract_dir/Hammered]
# cat auth.log | grep "Accepted password" | awk '{print $9}' | sort | uniq -c | sort -n
1 fido
5 user2
22 dhg
24 user3
28 root
38 user1
```

6

問5

哪個攻擊者的 IP 位址成功登入系統的次數最多？

同Q4只看IP

指令: `cat auth.log | grep "Accepted password" | grep root | awk '{print $11}' | sort | uniq -c | sort -n`

```
(root@kali)-[/home/kali/Desktop/temp_extract_dir/Hammered]
# cat auth.log | grep "Accepted password" | grep root | awk '{print $11}' | sort | uniq -c | sort -n
1 10.0.1.2
1 151.81.204.141
1 151.81.205.100
1 151.82.3.201
1 188.131.22.69
1 190.167.70.87
1 190.167.74.184
1 193.1.186.197
1 201.229.176.217
1 222.169.224.197
1 222.66.204.246
1 61.168.227.12
1 94.52.185.9
2 121.11.66.70
2 122.226.202.12
3 190.166.87.164
4 188.131.23.37
4 219.150.161.20
```

問6

有多少請求被傳送到 Apache 伺服器？

指令: `cat www-access.log | wc -l`

```
(root@kali)-[/home/.../Desktop/te]
# cat www-access.log | wc -l
365
```

365

問7

防火牆中新增了多少條規則？

指令: `cat auth.log | grep "iptables"`

```
# cat auth.log | grep "iptables"
Apr 15 12:49:09 app-1 sudo: user1 : TTY=pts/0 ; PWD=/opt/software/web/app ; USER=root ; COMMAND=/usr/bin/tee ../templates/proxy/iptables.conf
Apr 15 15:06:13 app-1 sudo: user1 : TTY=pts/1 ; PWD=/opt/software/web/app ; USER=root ; COMMAND=/usr/bin/tee ../templates/proxy/iptables.conf
Apr 15 15:17:45 app-1 sudo: user1 : TTY=pts/1 ; PWD=/opt/software/web/app ; USER=root ; COMMAND=/usr/bin/tee ../templates/proxy/iptables.conf
Apr 15 15:18:23 app-1 sudo: user1 : TTY=pts/1 ; PWD=/opt/software/web/app ; USER=root ; COMMAND=/usr/bin/tee ../templates/proxy/iptables.conf
Apr 24 19:25:37 app-1 sudo: root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -L
Apr 24 20:03:06 app-1 sudo: root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p ssh -dport 2424 -j ACCEPT
Apr 24 20:03:44 app-1 sudo: root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp -dport 53 -j ACCEPT
Apr 24 20:04:13 app-1 sudo: root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p udp -dport 53 -j ACCEPT
Apr 24 20:06:22 app-1 sudo: root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp -dport ssh -j ACCEPT
Apr 24 20:11:00 app-1 sudo: root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp -dport 53 -j ACCEPT
Apr 24 20:11:08 app-1 sudo: root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp -dport 113 -j ACCEPT
```

問8

目標系統上下載的其中一個檔案是一個掃描工具。該工具的名稱是什麼？

指令: `cat term.log | grep "Setting up"`

```
Setting up firestarter (1.0.3-0ubuntu1) ...
Setting up nmap (4.53-3) ...
Setting up dnsmasq (1:1.4-16.6ubuntu1) ...
```

nmap

問9

攻擊者使用 IP 219.150.161.20 的最後一次登入是什麼時候？格式：MM/DD/YYYY HH:MM:SS AM

指令: `cat auth.log | grep "219.150.161.20" | grep "Accepted password"`

但沒有年份...

```
(root@kali)-[/home/kali/Desktop/temp_extract_dir/Hammered]
# cat auth.log | grep "219.150.161.20" | grep "Accepted password"
Apr 19 05:41:44 app-1 sshd[8810]: Accepted password for root from 219.150.161.20 port 51249 ssh2
Apr 19 05:42:27 app-1 sshd[9031]: Accepted password for root from 219.150.161.20 port 40877 ssh2
Apr 19 05:55:20 app-1 sshd[12996]: Accepted password for root from 219.150.161.20 port 55545 ssh2
Apr 19 05:56:05 app-1 sshd[13218]: Accepted password for root from 219.150.161.20 port 36585 ssh2
```

看來是2010年 `exiftool auth.log`

```
# exiftool auth.log
ExifTool Version Number      : 13.10
File Name                    : auth.log
Directory                   : .
File Size                    : 10 MB
File Modification Date/Time  : 2010:07:03 13:53:20-04:00
File Access Date/Time       : 2025:08:17 05:11:47-04:00
File Inode Change Date/Time  : 2025:08:17 05:11:15-04:00
File Permissions             : -rwxrw-rw-
File Type                    : TXT
File Type Extension         : txt
MIME Type                    : text/plain
MIME Encoding                : us-ascii
Newlines                     : Unix LF
Line Count                   : 102164
Word Count                   : 1289927
```

2010-04-19 05:56

Q10

資料庫顯示兩個警告訊息。請提供最嚴重且可能有危險的一條。

指令: `cat daemon.log | grep "mysql" | grep "WARNING"`

```
(root@kali) [/home/kali/Desktop/temp_extract_dir/Hammered]
# cat daemon.log | grep "mysql" | grep "WARNING"
Mar 18 10:18:42 app-1 /etc/mysql/debian-start[7566]: WARNING: mysql.user contains 2 root accounts without password!
Mar 18 17:01:44 app-1 /etc/mysql/debian-start[14717]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 13:49:49 app-1 /etc/mysql/debian-start[5599]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 18:43:41 app-1 /etc/mysql/debian-start[4755]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 18:45:25 app-1 /etc/mysql/debian-start[4749]: WARNING: mysql.user contains 2 root accounts without password!
Mar 25 11:56:53 app-1 /etc/mysql/debian-start[4848]: WARNING: mysql.user contains 2 root accounts without password!
Apr 14 14:44:34 app-1 /etc/mysql/debian-start[5369]: WARNING: mysql.user contains 2 root accounts without password!
Apr 14 14:44:36 app-1 /etc/mysql/debian-start[5624]: WARNING: mysqlcheck has found corrupt tables
Apr 18 18:04:00 app-1 /etc/mysql/debian-start[4647]: WARNING: mysql.user contains 2 root accounts without password!
Apr 24 20:21:24 app-1 /etc/mysql/debian-start[5427]: WARNING: mysql.user contains 2 root accounts without password!
Apr 28 07:34:26 app-1 /etc/mysql/debian-start[4782]: WARNING: mysql.user contains 2 root accounts without password!
Apr 28 07:34:27 app-1 /etc/mysql/debian-start[5032]: WARNING: mysqlcheck has found corrupt tables
May 2 23:05:54 app-1 /etc/mysql/debian-start[4774]: WARNING: mysql.user contains 2 root accounts without password!
```

mysql.user contains 2 root accounts without password!

問11

目標系統上建立了多個帳戶。哪個帳戶是在 4 月 26 日 04:43:15 建立的？

指令: `cat auth.log | grep "Apr 26 04:43:15"`

```
(root@kali) [/home/kali/Desktop/temp_extract_dir/Hammered]
# cat auth.log | grep "Apr 26 04:43:15"
Apr 26 04:43:15 app-1 groupadd[20114]: new group: name=wind3str0y, GID=1005
Apr 26 04:43:15 app-1 useradd[20115]: new user: name=wind3str0y, UID=1004, GID=1005, home=/home/wind3str0y, shell=/bin/bash
```

wind3str0y

問12

少數攻擊者使用代理來執行掃描。該代理對應的用戶代理是什麼？

指令: `cat www-access.log | cut -d ' ' -f 12 | sort | uniq -c`

```
(root@kali) [/home/.../Desktop/temp_extract_dir/Hammered/apache2]
# cat www-access.log | cut -d ' ' -f 12 | sort | uniq -c
  8 "-"
272 "Apple-PubSub/65.12.1"
 32 "Mozilla/4.0"
 32 "Mozilla/5.0"
   3 "pxyscand/2.1"
 18 "WordPress/2.9.2;"
```

pxyscand/2.1